



Google עֵנָן

בלוג

צרו קשר עם המכירות

התחל בחינם

Google עֵנָן

בלוג

צרו קשר עם המכירות

התחל בחינם

מודיעין איומים

תוקף חמקמק מאוד ממנף את שרשרת האספקה של SolarWinds כדי לסכן מספר קורבנות גלובליים באמצעות דלת אחורית של SUNBURST

13 בדצמבר, 2020

מנדיאנט

נכתב על ידי: FireEye



[את UNC2452 עם APT29](#) עדכון (מאי 2022): מיזגנו פעילות UNC2452 המתוארת בפוסט זה מיוחסת כעת ל-APT29.

סיכום מנהלים

- גילינו קמפיין חדירה עולמי. אנו עוקבים אחר הגורמים העומדים מאחורי קמפיין זה כ-UNC2452.

במסגרת התוכנית שאלנו מנכ"ל
SUNBURST.

- פעילות התוקף לאחר הפריצה ממנפת טכניקות מרובות כדי להתחמק מגילוי ולהסתיר את פעילותו, אך מאמצים אלה מציעים גם הזדמנויות לגילוי.
- הקמפיין נרחב, ומשפיע על ארגונים ציבוריים ופרטיים ברחבי העולם.
- משחררת חתימות לזיהוי גורם איום זה FireEye ומתקפת שרשרת אספקה בשטח. חתימות אלה הציבורי שלנו. מוצרים [GitHub](#) נמצאות בדף ושירותים של FireEye יכולים לעזור ללקוחות לזהות ולחסום מתקפה זו.

תקציר

חשפה קמפיין נרחב, שאנו עוקבים אחריו כ FireEye הגורמים העומדים מאחורי קמפיין זה השיגו UNC2452. גישה לארגונים ציבוריים ופרטיים רבים ברחבי העולם. הם השיגו גישה לקורבנות באמצעות עדכונים טרואיאניים קמפיין זה. SolarWind של Orion לתוכנת ניטור וניהול החל ככל הנראה כבר באביב 2020 והוא נמשך כעת. פעילות לאחר הפריצה לשרשרת האספקה כללה תנועה רוחבית וגניבת נתונים. הקמפיין הוא עבודתו של גורם מיומן ביותר והפעולה בוצעה עם אבטחה תפעולית משמעותית.

דלת אחורית של SUNBURST

הוא רכיב SolarWinds.Orion.Core.BusinessLayer.dll במסגרת התוכנה SolarWinds חתום דיגיטלית של HTTP המכיל דלת אחורית שמתקשרת דרך Orion,

After an initial dormant period of up to two weeks, it retrieves and executes commands, called “Jobs”, that include the ability to transfer files, execute files, profile the system, reboot the machine, and disable system services. The malware masquerades its network traffic as the Orion Improvement Program (OIP) protocol and stores reconnaissance results within legitimate plugin configuration files allowing it to blend in with legitimate SolarWinds activity. The backdoor uses multiple obfuscated blocklists to identify forensic and anti-virus tools running as processes, services, and drivers.

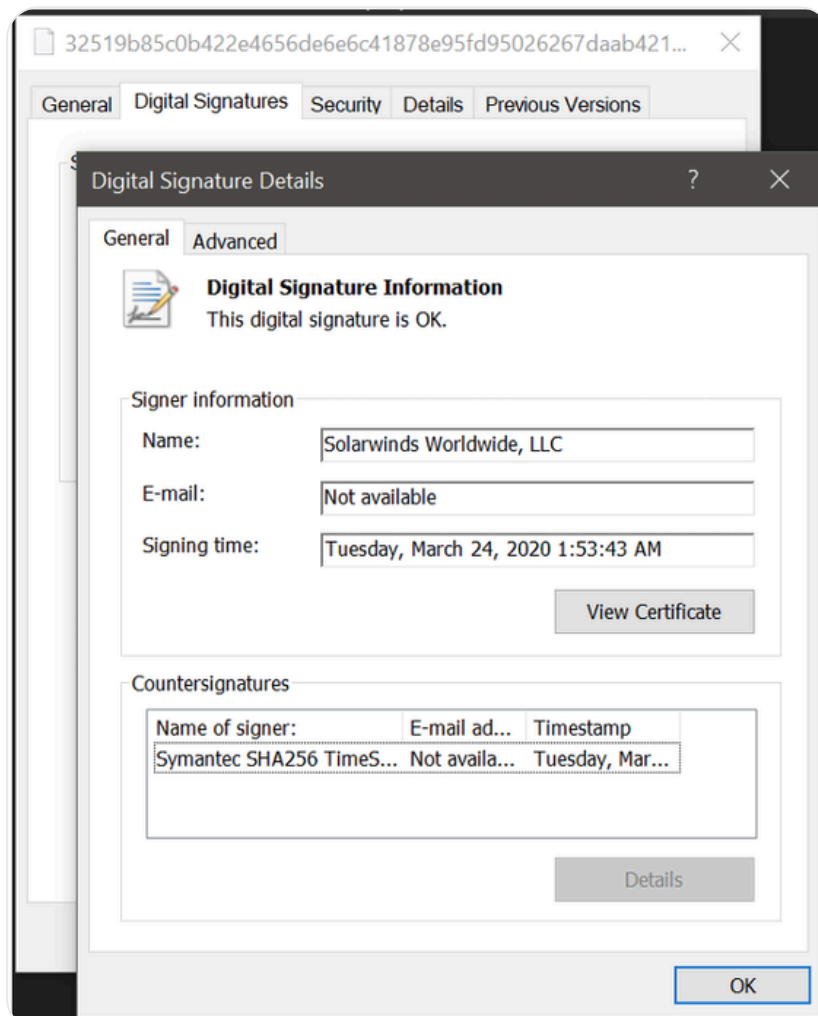


Figure 1: SolarWinds digital signature on software with backdoor

SolarWinds updates website, including.

- `hxxps://downloads.solarwinds[.]com/solarwind
s/CatalogResources/Core/2019.4/2019.4.5220.
20574/SolarWinds-Core-v2019.4.5220-
Hotfix5.msp`

The trojanized update file is a standard Windows Installer Patch file that includes compressed resources associated with the update, including the trojanized

SolarWinds.Orion.Core.BusinessLayer.dll component. Once the update is installed, the malicious DLL will be loaded by the legitimate SolarWinds.BusinessLayerHost.exe or SolarWinds.BusinessLayerHostx64.exe (depending on system configuration). After a dormant period of up to two weeks, the malware will attempt to resolve a subdomain of avsvmcloud[.]com. The DNS response will return a CNAME record that points to a Command and Control (C2) domain. The C2 traffic to the malicious domains is designed to mimic normal SolarWinds API communications. The list of known malicious infrastructure is available on FireEye's [GitHub page](#).

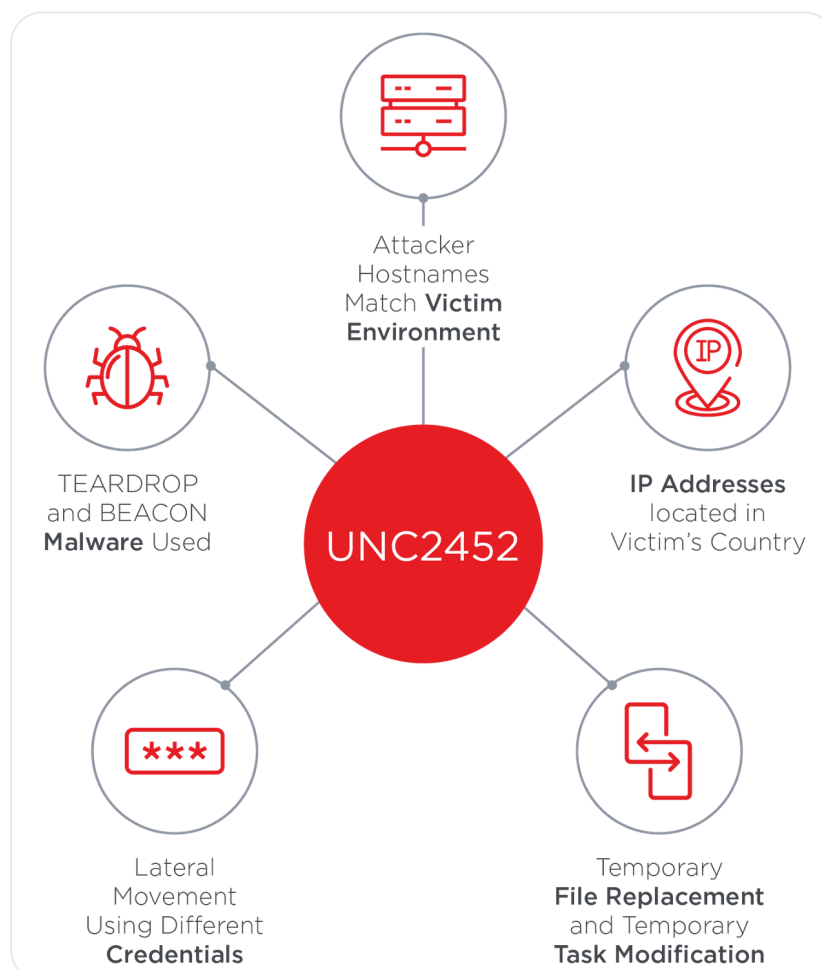
Worldwide Victims Across Multiple Verticals

FireEye has detected this activity at multiple entities worldwide. The victims have included government, consulting, technology, telecom and extractive entities in North America, Europe, Asia

FireEye has notified all entities we are aware of being affected.

Post Compromise Activity and Detection Opportunities

We are currently tracking the software supply chain compromise and related post intrusion activity as UNC2452. After gaining initial access, this group uses a variety of techniques to disguise their operations while they move laterally (Figure 2). This actor prefers to maintain a light malware footprint, instead preferring legitimate credentials and remote access for access into a victim's environment.



This section will detail the notable techniques and outline potential opportunities for detection.

TEARDROP and BEACON Malware Used

Multiple SUNBURST samples have been recovered, delivering different payloads. In at least one instance the attackers deployed a previously unseen memory-only dropper we've dubbed TEARDROP to deploy Cobalt Strike BEACON.

TEARDROP is a memory only dropper that runs as a service, spawns a thread and reads from the file "gracious_truth.jpg", which likely has a fake JPG header. Next it checks that HKU\SOFTWARE\Microsoft\CTF exists, decodes an embedded payload using a custom rolling XOR algorithm and manually loads into memory an embedded payload using a custom PE-like file format. TEARDROP does not have code overlap with any previously seen malware. We believe that this was used to execute a customized Cobalt Strike BEACON.

Mitigation: FireEye has provided two Yara rules to detect TEARDROP available on our [GitHub](#). Defenders should look for the following alerts from FireEye HX: MalwareGuard and WindowsDefender:

Process Information

file_operation_closed

file-path*:

"c:\windows\syswow64\netsetupsvc.dll

Window's defender Exploit Guard log entries:
(Microsoft-Windows-Security-Mitigations/KernelMode event ID 12)

Process"\Device\HarddiskVolume2\Windows\System32\svchost.exe" (PID XXXXX) would have been blocked from loading the non-Microsoft-signed binary
'\Windows\SysWOW64\NetSetupSvc.dll'

Attacker Hostnames Match Victim Environment

The actor sets the hostnames on their command and control infrastructure to match a legitimate hostname found within the victim's environment. This allows the adversary to blend into the environment, avoid suspicion, and evade detection.

Detection Opportunity

The attacker infrastructure leaks its configured hostname in RDP SSL certificates, which is identifiable in internet-wide scan data. This presents a detection opportunity for defenders -- querying internet-wide scan data sources for an organization's hostnames can uncover malicious IP addresses that may be masquerading as the organization. (Note: IP Scan history often shows IPs switching between default (WIN-*) hostnames and victim's hostnames) Cross-referencing the list of IPs identified in internet scan data with remote access logs may identify evidence of this actor in an environment. There is likely to be a single account per IP address.

The attacker's choice of IP addresses was also optimized to evade detection. The attacker primarily used only IP addresses originating from the same country as the victim, leveraging Virtual Private Servers.

Detection Opportunity

This also presents some detection opportunities, as geolocating IP addresses used for remote access may show an impossible rate of travel if a compromised account is being used by the legitimate user and the attacker from disparate IP addresses. The attacker used multiple IP addresses per VPS provider, so once a malicious login from an unusual ASN is identified, looking at all logins from that ASN can help detect additional malicious activity. This can be done alongside baselining and normalization of ASN's used for legitimate remote access to help identify suspicious activity.

Lateral Movement Using Different Credentials

Once the attacker gained access to the network with compromised credentials, they moved laterally using multiple different credentials. The credentials used for lateral movement were always different from those used for remote access.

Detection Opportunity

Organizations can use HX's LogonTracker module to graph all logon activity and analyze systems displaying a one-to-many relationship between source systems and accounts. This will uncover

uncommon occurrence during normal business operations.

Temporary File Replacement and Temporary Task Modification

The attacker used a temporary file replacement technique to remotely execute utilities: they replaced a legitimate utility with theirs, executed their payload, and then restored the legitimate original file. They similarly manipulated scheduled tasks by updating an existing legitimate task to execute their tools and then returning the scheduled task to its original configuration. They routinely removed their tools, including removing backdoors once legitimate remote access was achieved.

Detection Opportunity

Defenders can examine logs for SMB sessions that show access to legitimate directories and follow a delete-create-execute-delete-create pattern in a short amount of time. Additionally, defenders can monitor existing scheduled tasks for temporary updates, using frequency analysis to identify anomalous modification of tasks. Tasks can also be monitored to watch for legitimate Windows tasks executing new or unknown binaries.

This campaign's post compromise activity was conducted with a high regard for operational security, in many cases leveraging dedicated infrastructure per intrusion. This is some of the best operational security that FireEye has observed in a cyber attack, focusing on evasion

In-Depth Malware Analysis

SolarWinds.Orion.Core.BusinessLayer.dll (b91ce2fa41029f6955bff20079468448) is a SolarWinds-signed plugin component of the Orion software framework that contains an obfuscated backdoor which communicates via HTTP to third party servers. After an initial dormant period of up to two weeks, it retrieves and executes commands, called "Jobs", that include the ability to transfer and execute files, profile the system, and disable system services. The backdoor's behavior and network protocol blend in with legitimate SolarWinds activity, such as by masquerading as the Orion Improvement Program (OIP) protocol and storing reconnaissance results within plugin configuration files. The backdoor uses multiple blocklists to identify forensic and anti-virus tools via processes, services, and drivers.

Unique Capabilities

- Subdomain DomainName Generation Algorithm (DGA) is performed to vary DNS requests
 - CNAME responses point to the C2 domain for the malware to connect to
 - The IP block of A record responses controls malware behavior

- Command and control traffic masquerades as the legitimate Orion Improvement Program
- Code hides in plain site by using fake variable names and tying into legitimate components

Delivery and Installation

Authorized system administrators fetch and install updates to SolarWinds Orion via packages distributed by SolarWinds's website. The update package CORE-2019.4.5220.20574-SolarWinds-Core-v2019.4.5220-Hotfix5.msp

(02af7cec58b9a5da1c542b5a32151ba1) contains the SolarWinds.Orion.Core.BusinessLayer.dll described in this report. After installation, the Orion software framework executes the .NET program SolarWinds.BusinessLayerHost.exe to load plugins, including

SolarWinds.Orion.Core.BusinessLayer.dll. This plugin contains many legitimate namespaces, classes, and routines that implement functionality within the Orion framework. Hidden in plain sight, the class

SolarWinds.Orion.Core.BusinessLayer.OrionImprovementBusinessLayer implements an HTTP-based backdoor. Code within the logically unrelated routine

SolarWinds.Orion.Core.BusinessLayer.BackgroundInventory.InventoryManager.RefreshInternal invokes the backdoor code when the Inventory Manager plugin is loaded.

number

Of:e9:73:75:20:22:a6:06:ad:f2:a3:6e:34:5d:c0:ed.

The file was signed on March 24, 2020.

Initialization

On execution of the malicious SolarWinds.Orion.Core.BusinessLayer.OrionImprovementBusinessLayer.Initialize method the sample verifies that its lower case process name hashes to the value 17291806236368054941. This hash value is calculated as the standard FNV-1A 64-bit hash with an additional XOR by 6605813339339102567 after computing the FNV-1A. This hash matches a process named "solarwinds.businesslayerhost".

The sample only executes if the filesystem write time of the assembly is at least 12 to 14 days prior to the current time; the exact threshold is selected randomly from an interval. The sample continues to check this time threshold as it is run by a legitimate recurring background task. Once the threshold is met, the sample creates the named pipe 583da945-62af-10e8-4902-a8f205c72b2e to act as a guard that only one instance is running before reading

SolarWinds.Orion.Core.BusinessLayer.dll.config from disk and retrieving the XML field appSettings. The appSettings fields' keys are legitimate values that the malicious logic re-purposes as a persistent configuration. The key ReportWatcherRetry must be any value other than 3 for the sample to continue execution.

execution continues. A userID is generated by computing the MD5 of a network interface MAC address that is up and not a loopback device, the domain name, and the registry value HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Cryptography\MachineGuid. The userID is encoded via a custom XOR scheme after the MD5 is calculated. The ReportWatcherPostpone key of appSettings is then read from SolarWinds.Orion.Core.BusinessLayer.dll.config to retrieve the initial, legitimate value. This operation is performed as the sample later bit packs flags into this field and the initial value must be known in order to read out the bit flags. The sample then invokes the method Update which is the core event loop of the sample.

DGA and Blocklists

The backdoor determines its C2 server using a Domain Generation Algorithm (DGA) to construct and resolve a subdomain of avsvmcloud[.]com. The Update method is responsible for initializing cryptographic helpers for the generation of these random C2 subdomains. Subdomains are generated by concatenating a victim userID with a reversible encoding of the victims local machine domain name. The attacker likely utilizes the DGA subdomain to vary the DNS response to victims as a means to control the targeting of the malware. These subdomains are concatenated with one of the following to create the hostname to resolve:

- .appsync-api.eu-west-1[.]avsvmcloud[.]com

- .appsync-api.us-east-2[.]avsvmcloud[.]com

Process name, service name, and driver path listings are obtained, and each value is hashed via the FNV-1a + XOR algorithm as described previously and checked against hardcoded blocklists. Some of these hashes have been brute force reversed as part of this analysis, showing that these routines are scanning for analysis tools and antivirus engine components. If a blocklisted process is found the Update routine exits and the sample will continue to try executing the routine until the blocklist passes. Blocklisted services are stopped by setting their HKLM\SYSTEM\CurrentControlSet\services\<service_name>\Start registry entries to value 4 for disabled. Some entries in the service list if found on the system may affect the DGA algorithms behavior in terms of the values generated. The list of stopped services is then bit-packed into the ReportWatcherPostpone key of the appSettings entry for the samples' config file. If any service was transitioned to disabled the Update method exits and retries later. The sample retrieves a driver listing via the WMI query `Select * From Win32_SystemDriver`. If any blocklisted driver is seen the Update method exits and retries. If all blocklist tests pass, the sample tries to resolve `api.solarwinds.com` to test the network for connectivity.

Network Command and Control (C2)

via its DGA. The sample will delay for random intervals between the generation of domains; this interval may be any random value from the ranges 1 to 3 minutes, 30 to 120 minutes, or on error conditions up to 420 to 540 minutes (9 hours). The DNS A record of generated domains is checked against a hardcoded list of IP address blocks which control the malware's behavior. Records within the following ranges will terminate the malware and update the configuration key ReportWatcherRetry to a value that prevents further execution:

- 10.0.0.0/8
- 172.16.0.0/12
- 192.168.0.0/16
- 224.0.0.0/3
- fc00:: - fe00::
- fec0:: - ffc0::
- ff00:: - ff00::
- 20.140.0.0/15
- 96.31.172.0/24
- 131.228.12.0/22
- 144.86.226.0/24

Once a domain has been successfully retrieved in a CNAME DNS response the sample will spawn a new thread of execution invoking the method HttpHelper.Initialize which is responsible for all C2 communications and dispatching. The HTTP thread begins by delaying for a configurable amount of time that is controlled by the SetTime command. The HTTP thread will delay for a

if the sample is attempting to send outbound data the content-type HTTP header will be set to "application/octet-stream" otherwise to "application/json".

A JSON payload is present for all HTTP POST and PUT requests and contains the keys "userId", "sessionId", and "steps". The "steps" field contains a list of objects with the following keys: "Timestamp", "Index", "EventType", "EventName", "DurationMs", "Succeeded", and "Message". The JSON key "EventType" is hardcoded to the value "Orion", and the "EventName" is hardcoded to "EventManager". Malware response messages to send to the server are DEFLATE compressed and single-byte-XOR encoded, then split among the "Message" fields in the "steps" array. Each "Message" value is Base64 encoded separately. Not all objects in the "steps" array contribute to the malware message – the integer in the "Timestamp" field must have the 0x2 bit set to indicate that the contents of the "Message" field are used in the malware message. Step objects whose bit 0x2 is clear in the Timestamp field contain random data and are discarded when assembling the malware response.

Steganography

In observed traffic these HTTP response bodies attempt to appear like benign XML related to .NET assemblies, but command data is actually spread across the many GUID and HEX strings present. Commands are extracted from HTTP response

Command data is spread across multiple strings that are disguised as GUID and HEX strings. All matched substrings in the response are filtered for non HEX characters, joined together, and HEX-decoded. The first DWORD value shows the actual size of the message, followed immediately with the message, with optional additional junk bytes following. The extracted message is single-byte XOR decoded using the first byte of the message, and this is then DEFLATE decompressed. The first character is an ASCII integer that maps to the JobEngine enum, with optional additional command arguments delimited by space characters.

Commands are then dispatched to a JobExecutionEngine based upon the command value as described next.

Supported Commands

<u>Command</u>	<u>Value</u>
Idle	0
Exit	1
SetTime	2

CollectSystemDescription	3	

UploadSystemDescription	4	
RunTask	5	
GetProcessByDescription	6	

KillTask	7	
GetFileSystemEntries	8	
WriteFile	9	

FileExists	10	
DeleteFile	11	
GetFileHash	12	

ReadRegistryValue	13
SetRegistryValue	14
DeleteRegistryValue	15
GetRegistrySubKeyAndValueNames	16
Reboot	17

Indicators and Detections to Help the Community

To empower the community to detect this supply chain backdoor, we are publishing indicators and detections to help organizations identify this backdoor and this threat actor. The signatures are a mix of Yara, IOC, and Snort formats.

A list of the detections and signatures are available on the [Mandiant GitHub repository](#). We are releasing detections and will continue to update the public repository with overlapping detections for host and network-based indicators as we develop new or refine existing ones. We have found multiple hashes with this backdoor and we will post updates of those hashes.

MITRE ATT&CK Techniques Observed

<u>ID</u>	<u>Description</u>
T1012	Query Registry
T1027	Obfuscated Files or Information

T1070.004	File Deletion
T1071.001	Web Protocols
T1071.004	Application Layer Protocol: DNS
T1083	File and Directory Discovery
T1105	Ingress Tool Transfer
T1132.001	Standard Encoding
T1195.002	Compromise Software Supply Chain
T1518	Software Discovery
T1518.001	Security Software Discovery
T1543.003	Windows Service
T1553.002	Code Signing
T1568.002	Domain Generation Algorithms
T1569.002	Service Execution
T1584	Compromise Infrastructure

Prior to following SolarWind's recommendation to utilize Orion Platform release 2020.2.1 HF 1, which is currently available via the SolarWinds Customer Portal, organizations should consider preserving impacted devices and building new systems using the latest versions. Applying an upgrade to an impacted box could potentially overwrite forensic evidence as well as leave any additional backdoors on the system. In addition, [SolarWinds has released additional mitigation and hardening instructions](#).

In the event you are unable to follow SolarWinds' recommendations, the following are immediate mitigation techniques that could be deployed as first steps to address the risk of trojanized SolarWinds software in an environment. If attacker activity is discovered in an environment, we recommend conducting a comprehensive investigation and designing and executing a remediation strategy driven by the investigative findings and details of the impacted environment.

- Ensure that SolarWinds servers are isolated / contained until a further review and investigation is conducted. This should include blocking all Internet egress from SolarWinds servers.
- If SolarWinds infrastructure is not isolated, consider taking the following steps:
 - Restrict scope of connectivity to endpoints from SolarWinds servers,

- הגבל את היקף החשבונות בעלי הרשאות מנהל מקומיות בשרתי SolarWinds.
- חסום יציאה מהאינטרנט משרתים או נקודות קצה אחרות בעזרת תוכנת SolarWinds.
- שקלו (לפחות) לשנות סיסמאות עבור חשבונות בעלי גישה לשרתי/תשתית של SolarWinds. בהתבסס על סקירה/חקירה נוספת, ייתכן שיידרשו אמצעי תיקון נוספים.
- אם SolarWinds משמשת לניהול תשתית רשת, יש לשקול לבצע סקירה של תצורות התקני הרשת לאיתור שינויים בלתי צפויים/לא מורשים. שימו לב, זהו צעד פרואקטיבי עקב היקף הפונקציונליות של SolarWinds, שאינו מבוסס על ממצאי חקירה.

תודות

פוסט זה בבלוג היה פרי מאמץ משותף של אנשי צוות וצוותים רבים מ-FireEye. תודה מיוחדת ל:

אנדרו ארצ'ר, דאג בינסטוק, כריס די-ג'יאמו, גלן אדוארדס, ניק הורניק, אלכס פנינו, אנדרו רקטור, סקוט ראנלס, אריק סקיילס, נלאני פרייזר, שרה ג'ונס, ג'ון הולטקוויסט, בן ריד, ג'ון לת'רי, פרד האוס, דיליפ ג'אלפאלי, מייקל סיקורסקי, סטיבן אקלס, וויליאם באלנטין, ג'יי סמית', אלכס ברי, ניק ריצ'רד, איזיף איברהימה, דן פרז, מרסין סידלרז, בן ווית'נל, בארי ונגריק, ניקול אופנהיים, איאן אהל, אנדרו תומפסון, מאט דאנוודי, אוון ריס, סטיב מילר, אליסה רחמן, ג'ון גורמן, לנארד גלאנג, סטיב סטון, ניק בנט, מת'יו מקוויירט, מייק ברנס, עומר בייג.

תודה מיוחדת גם לניק קאר, כריסטופר גלייר וראמין נאפיסי ממיקרוסופט.

מאמרים קשורים



Threat Intelligence

Google Cloud

מודיעין איומים

מחפשים ייעוץ משפטי: קמפיין
ממוקד מתמשך נגד משרדי עורכי
דין אמריקאים

דקות קריאה 19 • מנדיאנט מאת



Threat Intelligence

Google Cloud

מודיעין איומים

ניצול פגיעות ביטול סריאליזציה
של KnowledgeDeliver דרך
ViewState

7 דקות קריאה של • מנדיאנט מאת



Threat Intelligence

Google Cloud

מודיעין איומים

2 PhaaS 2 Furious: האבולוציה של
שירותי פישנינג בשפה הסינית

דקות 7 • קבוצת מודיעין האיומים מאת
של גוגל קריאה

Threat Intelligence

Google Cloud

מודיעין איומים

ברוכים הבאים ל-BlackFile: בתוך
מבצע סחיטה של ויישינג

דקות 16 • קבוצת מודיעין האיומים מאת
של גוגל קריאה

Google עֵנָן

בלוג

צרו קשר עם המכירות

התחל בחינם



גוגל קלאוד

מוצרי גוגל קלאוד

פְּרָטִיּוּת

תנאים



עֲזָרָה

אֲנִגְלִית